PCI DSS Network Segmentation

Complete Implementation Guide

A GRC Project Documentation & Best Practices

Document Version: 1.0

Prepared Date: February 12, 2026

Prepared By: Siddique Reza Khan

Dedicated to: Taimur Ijlal

Table of Contents

Project Overview.....4
Project Objectives.....4
Section 1: Understanding PCI DSS Scope.....5
1.1 What is PCI DSS Scope?.....5
Cardholder Data Includes:.....5
Sensitive Authentication Data:.....5
1.2 Three Categories of Systems.....5
1.3 Scoping Methodology.....6
Section 2: Network Segmentation Fundamentals.....8
2.1 What is Network Segmentation?.....8
2.2 Benefits of Segmentation.....8
2.3 Segmentation Methods.....8
Section 3: Implementing Network Segmentation.....10
3.1 Planning Phase.....10
Step 1: Define Segmentation Strategy.....10
Step 2: Network Design.....10
Step 3: Security Controls Planning.....10
3.2 Implementation Phase.....10
Firewall Rule Principles.....10
Example Firewall Rules.....10
Section 4: Segmentation Testing.....11
4.1 PCI DSS Requirement 11.4.5.....11
4.2 Testing Methodology.....11
4.3 Testing Scenarios.....12
Section 5: Documentation Requirements.....13
5.1 Essential Documentation.....13
5.2 Scope Determination Template.....13
Section 6: Ongoing Maintenance.....14
6.1 Regular Activities.....14
6.2 Change Management.....14
Section 7: Best Practices.....15
7.1 Design Principles.....15
7.2 Implementation Tips.....15
Section 8: Practical Implementation Example.....16
8.1 Example Scenario.....16
8.2 Network Segmentation Design.....16
Conclusion.....18

Appendices..... 19
Appendix A: Glossary..... 19
Appendix B: Implementation Checklist..... 20
Appendix C: Resources..... 20

Project Overview

This comprehensive guide provides step-by-step instructions for completing a PCI DSS Network Segmentation project. Network segmentation is a critical security control that isolates the Cardholder Data Environment (CDE) from other network components, reducing PCI DSS scope and enhancing security posture.

Project Objectives

1. Define and document PCI DSS scope boundaries
2. Implement effective network segmentation controls
3. Validate segmentation effectiveness through testing
4. Reduce PCI DSS assessment scope
5. Enhance security by limiting potential attack paths
6. Create comprehensive documentation for auditors

```
┌──────────────────────────────────────────────────────────────────────────┐
│                    SEGMENTATION: COMPLIANCE VS REALITY                   │
├──────────────────────────────────────────────────────────────────────────┤
│                                                                          │
│   COMPLIANCE THEATRE                    REAL GRC WORK                    │
│   ────────────────────                  ─────────────                    │
│   Draw a box around CDE                 Define what ACTUALLY is CDE      │
│   Label it "segmented"                  Examine trust relationships      │
│   Move on                               Question implicit trust          │
│                                         Document where design fails      │
│                                         Anticipate QSA challenges        │
│                                                                          │
└──────────────────────────────────────────────────────────────────────────┘
```

Section 1: Understanding PCI DSS Scope

1.1 What is PCI DSS Scope?

PCI DSS scope encompasses all system components that store, process, or transmit cardholder data (CHD), or could impact the security of the Cardholder Data Environment.

Cardholder Data Includes:

- Primary Account Number (PAN)
- Cardholder Name
- Expiration Date
- Service Code

Sensitive Authentication Data:

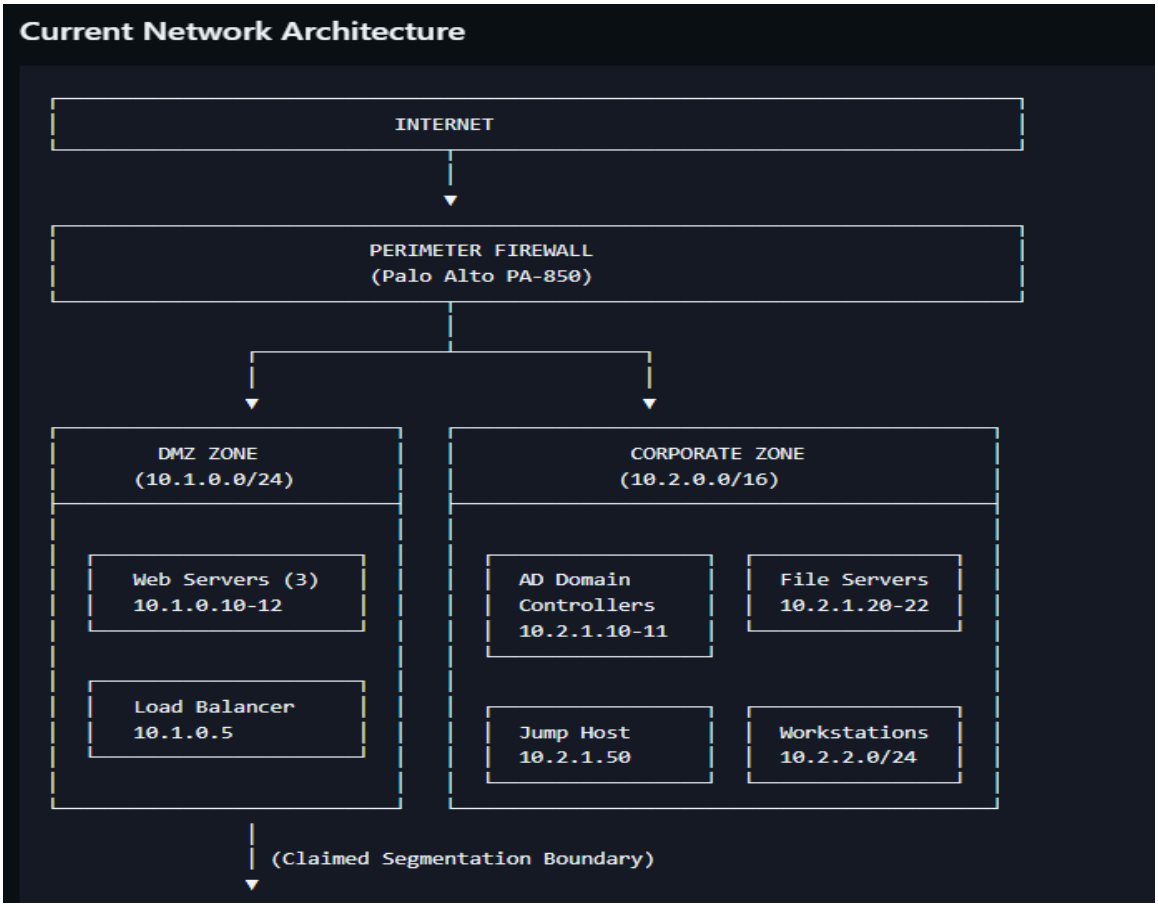
- Full magnetic stripe data
- CAV2/CVC2/CVV2/CID
- PINs and PIN blocks

1.2 Three Categories of Systems

Category	Description
In-Scope Systems	Systems that store, process, or transmit cardholder data. Examples: Payment terminals, POS systems, payment gateways, databases with CHD, applications processing payments.
Connected Systems	Systems that connect to or can impact in-scope systems. Examples: Network devices providing connectivity, security systems protecting CDE, management systems with CDE access.
Out-of-Scope Systems	Systems completely isolated from the CDE with no connection or access path to cardholder data. Cannot impact CDE security.

1.3 Scoping Methodology

Step	Activities
Step 1: Data Discovery	Identify all locations where cardholder data exists, map data flows throughout organization, document all systems touching CHD
Step 2: Asset Inventory	Create comprehensive inventory of all systems, document network connectivity, identify system owners and purposes
Step 3: Data Flow Analysis	Map how cardholder data moves through systems, identify all processing points, document transmission methods and protocols
Step 4: Boundary Definition	Define clear boundaries of the CDE, identify all connection points, document segmentation controls



```
┌──────────────────────────────────────────────────────────────────────────┐
│                    CARDHOLDER DATA ENVIRONMENT (CDE)                     │
│                          (10.3.0.0/24)                                   │
├──────────────────────────────────────────────────────────────────────────┤
│                                                                          │
│   ┌──────────────────┐   ┌──────────────────┐   ┌──────────────────┐    │
│   │ Payment App      │   │ Card Database    │   │ HSM Appliance    │    │
│   │ Server           │   │ Server           │   │                  │    │
│   │ 10.3.0.10        │   │ 10.3.0.20        │   │ 10.3.0.30        │    │
│   └──────────────────┘   └──────────────────┘   └──────────────────┘    │
│                                                                          │
│   ┌──────────────────┐   ┌──────────────────┐                          │
│   │ Tokenization     │   │ Log Collector    │                          │
│   │ Service          │   │ (Splunk Forwarder)│                          │
│   │ 10.3.0.40        │   │ 10.3.0.50        │                          │
│   └──────────────────┘   └──────────────────┘                          │
│                                                                          │
└──────────────────────────────────────────────────────────────────────────┘
                                  │
                                  ▼
┌──────────────────────────────────────────────────────────────────────────┐
│                          MANAGEMENT ZONE                                 │
│                          (10.4.0.0/24)                                   │
├──────────────────────────────────────────────────────────────────────────┤
│                                                                          │
│   ┌──────────────────┐   ┌──────────────────┐   ┌──────────────────┐    │
│   │ SIEM (Splunk)    │   │ Backup Server    │   │ Patch Management │    │
│   │ 10.4.0.10        │   │ 10.4.0.20        │   │ (WSUS)           │    │
│   │                  │   │                  │   │ 10.4.0.30        │    │
│   └──────────────────┘   └──────────────────┘   └──────────────────┘    │
│                                                                          │
└──────────────────────────────────────────────────────────────────────────┘
```

Section 2: Network Segmentation Fundamentals

2.1 What is Network Segmentation?

Network segmentation divides a computer network into smaller, isolated sections. In PCI DSS context, it separates the CDE from other network segments to:

- Reduce assessment scope
- Limit lateral movement in case of breach
- Focus security resources on critical systems
- Simplify compliance efforts

2.2 Benefits of Segmentation

Security Benefits	Compliance Benefits	Operational Benefits
• Contains breaches **• Reduces attack surface** **• Limits lateral movement** **• Improves detection**	• Reduces in-scope systems • Decreases audit complexity • Lowers compliance costs • Simplifies evidence	• Improves performance • Enables targeted controls • Facilitates troubleshooting • Flexible security policies

2.3 Segmentation Methods

Method	Description	Characteristics
Physical Segmentation	Completely separate hardware and network infrastructure with no physical connection	• Highest isolation • Most expensive • Complete separation
Logical Segmentation	VLANs, firewalls with strict rules, NAC, Software-Defined Networking	• Cost effective • Flexible • Requires proper config
Hybrid Approach	Combination of physical and logical controls	• Most common • Balances security/cost • Practical

```
DATA FLOW ANALYSIS:

Customer Browser
        │
        ▼ (HTTPS - PAN entered)
┌──────────────┐
│  Web Server  │──────────────────────────────┐
└──────────────┘                              │
        │                                     │
        ▼ (API Call - PAN in transit)         │
┌──────────────┐                              │
│ Payment App  │                              │
└──────────────┘                              │
        │                                     │
        ├──────────────┐                      │
        │              │                      │
        ▼              ▼                      ▼
┌──────────────┐  ┌──────────────┐  ┌──────────────┐
│     HSM      │  │   Card DB    │  │  Log Server  │
│ (Encryption) │  │  (Storage)   │  │  (Contains   │
└──────────────┘  └──────────────┘  │   PAN logs?) │
                                    └──────────────┘

QUESTION: Is the log server in scope? What data does it receive?
```

Section 3: Implementing Network Segmentation

3.1 Planning Phase

Step 1: Define Segmentation Strategy

- Identify segmentation objectives
- Select appropriate segmentation methods
- Define segment boundaries
- Plan for future growth

Step 2: Network Design

- Create network architecture diagrams
- Define subnet structures
- Plan IP addressing scheme
- Design firewall rule sets

Step 3: Security Controls Planning

- Identify required security controls
- Plan firewall configurations
- Design access control policies
- Plan monitoring and logging

3.2 Implementation Phase

Firewall Rule Principles

- Default deny all traffic
- Explicitly allow only necessary traffic
- Document all rules with business justification
- Review rules at least every 6 months

Example Firewall Rules

Rule	Description	Justification	Review Date
permit tcp 192.168.1.0/24 host 10.0.1.100 eq 443	Allow web servers to payment gateway	Process credit card transactions	2026-08-01
permit tcp host 192.168.1.50 host 10.0.1.200 eq 3306	Allow app server to CDE database	Retrieve transaction data	2026-08-01
deny ip any 10.0.1.0/24	Deny all other CDE access	Default deny security	2026-08-01

Section 4: Segmentation Testing

4.1 PCI DSS Requirement 11.4.5

Requirement: Segmentation controls are tested as follows:

- At least every six months and after any changes to segmentation controls/methods
- By an internal qualified resource or external third party
- To confirm that segmentation is effective

4.2 Testing Methodology

Phase	Activities
Phase 1: Planning	Define test scope, identify test systems, obtain necessary approvals, schedule testing window
Phase 2: Reconnaissance	Network mapping, service discovery, vulnerability scanning, information gathering
Phase 3: Testing	Attempt CDE access from outside, test firewall rules, attempt to bypass controls, test all documented paths
Phase 4: Reporting	Document findings, classify vulnerabilities, provide remediation guidance, create executive summary

4.3 Testing Scenarios

Scenario	Objective	Expected Result
External to CDE	Verify external networks cannot access CDE. Test: ping CDE, connect to services, scan ports, access applications	All attempts fail
Guest WiFi to CDE	Verify guest network isolation from CDE. Test: access CDE IPs, routing, DNS lookups, corporate resources	Complete isolation
Workstation to CDE	Verify workstations cannot directly access CDE. Test: access systems, databases, unauthorized pathways	Access denied
Lateral Movement	Verify segmentation limits lateral movement. Test: privilege escalation, pivot to CDE, vulnerable pathways	Unable to reach CDE

Areas to Investigate:

Connection Type	Question	Risk Level
Authentication	Does CDE use corporate AD?	HIGH
DNS	Where do CDE systems resolve DNS?	MEDIUM
Time Sync	NTP source for CDE systems?	LOW
Patching	How are CDE systems patched?	HIGH
Backup	Where do backups go? Do they contain CHD?	HIGH
Logging	Where do logs flow? What's in them?	MEDIUM
Administration	Who has admin access? From where?	HIGH

Section 5: Documentation Requirements

5.1 Essential Documentation

Document Type	Required Contents
Network Diagrams	Current state architecture, logical topology, physical layout, data flow diagrams, segmentation boundaries clearly marked
Firewall Documentation	Complete rule sets, rule justifications, review dates and ownership, change history, testing results
Scope Documentation	System inventory, in-scope system list, connected system list, out-of-scope justification, scope validation evidence
Testing Documentation	Test plans and procedures, testing results and evidence, remediation records, re-test results, sign-off documentation

5.2 Scope Determination Template

Use this template to document your PCI DSS scope determination:

System Name	Description	Location	CHD Status
[System 1]	[Description]	[Location]	[Yes/No]
[System 2]	[Description]	[Location]	[Yes/No]
[System 3]	[Description]	[Location]	[Yes/No]

Section 6: Ongoing Maintenance

6.1 Regular Activities

Frequency	Activities
Monthly	Review firewall logs, check for unauthorized changes, verify monitoring is active, review access logs
Quarterly	Review and update network diagrams, validate scope boundaries, review firewall rules, test key segmentation controls
Semi-Annually	Conduct full segmentation testing, review all documentation, update risk assessments, validate control effectiveness
Annually	Complete PCI DSS assessment, review segmentation strategy, update policies and procedures, comprehensive security review

6.2 Change Management

All Changes Require:

7. Change request documentation
8. Security impact assessment
9. Testing before implementation
10. Updated documentation
11. Rollback plan
12. Post-implementation validation

Section 7: Best Practices

7.1 Design Principles

Principle	Description
Defense in Depth	Multiple layers of security controls to protect against various attack vectors
Least Privilege	Provide only the minimum access necessary for users and systems to perform their functions
Zero Trust	Verify everything, trust nothing. Authenticate and authorize every access request
Simplicity	Simple designs are easier to secure, maintain, and troubleshoot
Documentation	Maintain comprehensive and current documentation for all systems and processes

7.2 Implementation Tips

- Start with clear scope definition
- Document everything from the beginning
- Test before production deployment
- Implement change management early
- Train staff on new procedures
- Plan for ongoing maintenance
- Build relationships with auditors

Section 8: Practical Implementation Example

8.1 Example Scenario

Aspect	Details
Organization	Mid-sized retail company with e-commerce operations
Challenge	E-commerce website shares infrastructure with corporate network, increasing PCI scope
Goal	Implement segmentation to reduce PCI scope and improve security posture

8.2 Network Segmentation Design

Segment	Network	Purpose
CDE Segment	10.0.1.0/24	Payment processing systems only, strict firewall controls, no direct internet access, dedicated monitoring
DMZ Segment	10.0.2.0/24	Web and application servers, limited CDE access, internet-facing
Corporate Segment	192.168.1.0/24	Employee workstations, no CDE access, standard security controls
Management Segment	10.0.3.0/24	IT administration, jump boxes for CDE access, enhanced logging

```
┌──────────────────────────────────────────────────────────────────────────┐
│                        COMMON SEGMENTATION FAILURES                      │
├──────────────────────────────────────────────────────────────────────────┤
│                                                                          │
│  1. SHARED SERVICES                                                      │
│                                                                          │
│     ┌─────────┐          ┌─────────┐          ┌─────────┐               │
│     │Corporate│ ────────▶│   AD    │◀──────── │   CDE   │               │
│     │  Zone   │          │ Server  │          │         │               │
│     └─────────┘          └─────────┘          └─────────┘               │
│                               │                                          │
│     If AD is compromised, attacker has credentials for CDE               │
│                                                                          │
│  2. JUMP HOST AS SINGLE POINT                                            │
│                                                                          │
│     ┌─────────┐          ┌─────────┐          ┌─────────┐               │
│     │ Admin   │ ────────▶│ Jump    │────────▶ │ CDE     │               │
│     │Workstatn│          │ Host    │          │ Systems │               │
│     └─────────┘          └─────────┘          └─────────┘               │
│                               │                                          │
│     Compromise jump host = access to entire CDE                          │
│                                                                          │
│  3. LOG AGGREGATION                                                      │
│                                                                          │
│     ┌─────────┐                                ┌─────────┐               │
│     │ CDE     │ ─── logs (with PAN?) ────────▶ │ SIEM    │               │
│     │ Systems │                                │(Outside │               │
│     └─────────┘                                │ CDE)    │               │
│                                                └─────────┘               │
│     If logs contain CHD, SIEM is in scope                                │
│                                                                          │
│  4. BACKUP PATHS                                                         │
│                                                                          │
│     ┌─────────┐          ┌─────────┐          ┌─────────┐               │
│     │ CDE     │ ────────▶│ Backup  │────────▶ │ Tape    │               │
│     │ DB      │          │ Server  │          │ Storage │               │
│     └─────────┘          └─────────┘          └─────────┘               │
│                                                                          │
│     Backups contain CHD - entire backup chain is in scope                │
│                                                                          │
└──────────────────────────────────────────────────────────────────────────┘
```

Conclusion

Implementing effective network segmentation for PCI DSS compliance requires careful planning, methodical execution, rigorous testing, and ongoing maintenance. This guide provides the foundation for a successful segmentation project that will:

- Reduce PCI DSS scope
- Enhance security posture
- Streamline compliance efforts
- Protect cardholder data

Remember that segmentation is not a one-time project but an ongoing process that requires regular review, testing, and updates to remain effective.

Appendices

Appendix A: Glossary

Term	Definition
CDE	Cardholder Data Environment - Systems that store, process, or transmit cardholder data
CHD	Cardholder Data - Primary account number, cardholder name, expiration date, service code
PAN	Primary Account Number - The unique payment card number
PCI DSS	Payment Card Industry Data Security Standard - Security standard for organizations handling card data
QSA	Qualified Security Assessor - Certified professional who conducts PCI DSS assessments
SAD	Sensitive Authentication Data - Full track data, CAV2/CVC2/CVV2/CID, PINs
VLAN	Virtual Local Area Network - Logical network segmentation on physical infrastructure

Appendix B: Implementation Checklist

Phase	Task	Status
Pre-Implementation	Scope defined and documented	☐ Complete
Pre-Implementation	Network diagrams created	☐ Complete
Implementation	Infrastructure deployed	☐ Complete
Implementation	Firewalls configured	☐ Complete
Testing	Test plan created and executed	☐ Complete
Documentation	All documentation completed	☐ Complete

Appendix C: Resources

Category	Resources
Documentation	PCI DSS v4.0 Requirements, Information Supplement: Scoping and Segmentation, PCI DSS Glossary
Testing Tools	Nmap (network scanning), Metasploit (penetration testing), Wireshark (traffic analysis), Nessus (vulnerability scanning)
Diagramming	Draw.io, Lucidchart, Microsoft Visio
Training	PCI SSC Training Programs, SANS Security Training, (ISC)² Certification Programs, Cloud Security Alliance

END OF DOCUMENT